



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Firewalls and Intrusion Detection

Outline



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Firewalls
 - Filtering firewalls
 - Proxy firewalls
- Intrusion Detection System (IDS)
 - Rule-based IDS
 - Anomaly detection IDS
 - Host-based vs. network-based IDS

Basic Terms



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Vulnerabilities
- Intrusions (attacks) and Intrusion Detection Systems (IDS)
- Alert or alarm: message generated by IDS

Example Attacks

- Disclosure, modification, and destruction of data
- Compromise host and then attack other systems
- Monitoring and capture of user passwords, then masquerade as authorized user



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Firewalls

- Provides secure connectivity between networks
- Implements and enforces a security policy for communication between networks



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Firewall Capabilities

- Controlled access
 - restrict incoming and outgoing traffic according to security policy
- Other functions
 - log traffic, for later analysis
 - network address translation
 - encryption / decryption
 - application (payload) transformations



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Limitations of Firewalls

- Cannot protect against traffic that does not cross it
 - i.e., there may be other ingress points to the network, such as modems or wireless access points, that bypass the firewall
 - doesn't protect against "insider" attacks
- Configuration of firewalls to accomplish a desired high-level security policy is non-trivial



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Filtering



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Compare traffic to patterns, then process traffic according to rules if matched
- Two styles
 - packet filtering
 - session filtering

Packet Filtering

- Patterns specify values in the header of a single packet, e.g.,
 - source IP address and port number
 - destination IP address and port number
 - transport protocol type



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
ROLLA, MISSOURI

Packet Filtering (cont'd)



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Decisions made on a per-packet basis
 - no **state** information (about previous packets) is maintained or used
- Assessment
 - easy to implement
 - but limited capabilities
- May be subject to **tiny-fragment** attack
 - first fragment has only a few bytes
 - rest of TCP header in a second fragment, not examined by firewall

Session Filtering

- Packet decisions are made in the context of a *connection or flow* of packets
- If packet is the start of a new connection...
 - check against rules for new connections
- If packet is part of an existing connection...
 - check against state-based rules for existing connections
 - update state of this connection
- More powerful than packet filtering, can recognize more sophisticated threats or implement more complex policies
- But also more expensive to implement



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Proxy Firewalls

- Serve as *relays* for connections
- Two flavors
 1. application level
 2. circuit level



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Application Proxies



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Understand specific application protocols, e.g., HTTP, SMTP, SSH
 - proxy 'impersonates' both one side of connection to the other
- Can do arbitrary processing / inspection of application payloads
 - ex.: check email for viruses before forwarding
- Computationally expensive
- Must write a new proxy application to support new protocols
- May require hosts inside the organization to be configured to use the proxy



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Circuit-Level Proxies

- Sets up two connections, one to inside user, one to outside server
 - i.e., proxy at the TCP level, rather than the application level
 - client programs **must** be aware they are using a circuit-level proxy, by linking to modified libraries
- Users must authenticate to proxy before connection to outside will be established
- Example protocol: SOCKS



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Overview of IDS

Attack Stages



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Intelligence gathering attacker probes the system to determine vulnerabilities
- Planning: deciding what resource to attack and how
- Attack execution
- Hiding: covering traces of the attack
- Preparation for future attacks: install “back doors” for unhindered access
- Example: Advanced and Persistent Threats (APT): exfiltrates highly confidential information like trade secrets, or damages the victim, e.g., Stuxnet worm

Intrusion Detection System

- Detect if attacks are being attempted, or if system has been compromised
- Desirable features
 - Accuracy
 - Fast
 - Flexible, general
 - Results easy to understand



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Measuring Accuracy

- *Events* are actions occurring in the system (file accesses, login attempts, etc.)
 - an *intrusion* (I) is an event that is part of an attack
 - an *alarm* (A) is generated if an event is diagnosed as being an intrusion

	Intrusion	Not an Intrusion
Alarm Generated	True positive	False positive
Alarm Not Generated	False negative	True negative



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Measuring (Cont'd)

- True positive rate: fraction of intrusions correctly diagnosed (detected)
- False negative rate: fraction of intrusions incorrectly diagnosed (not detected)
 - $FNR = 1 - TPR$
- True negative rate: fraction of non-intrusions correctly diagnosed
- False positive rate: fraction of non-intrusions incorrectly diagnosed
 - $FPR = 1 - TNR$

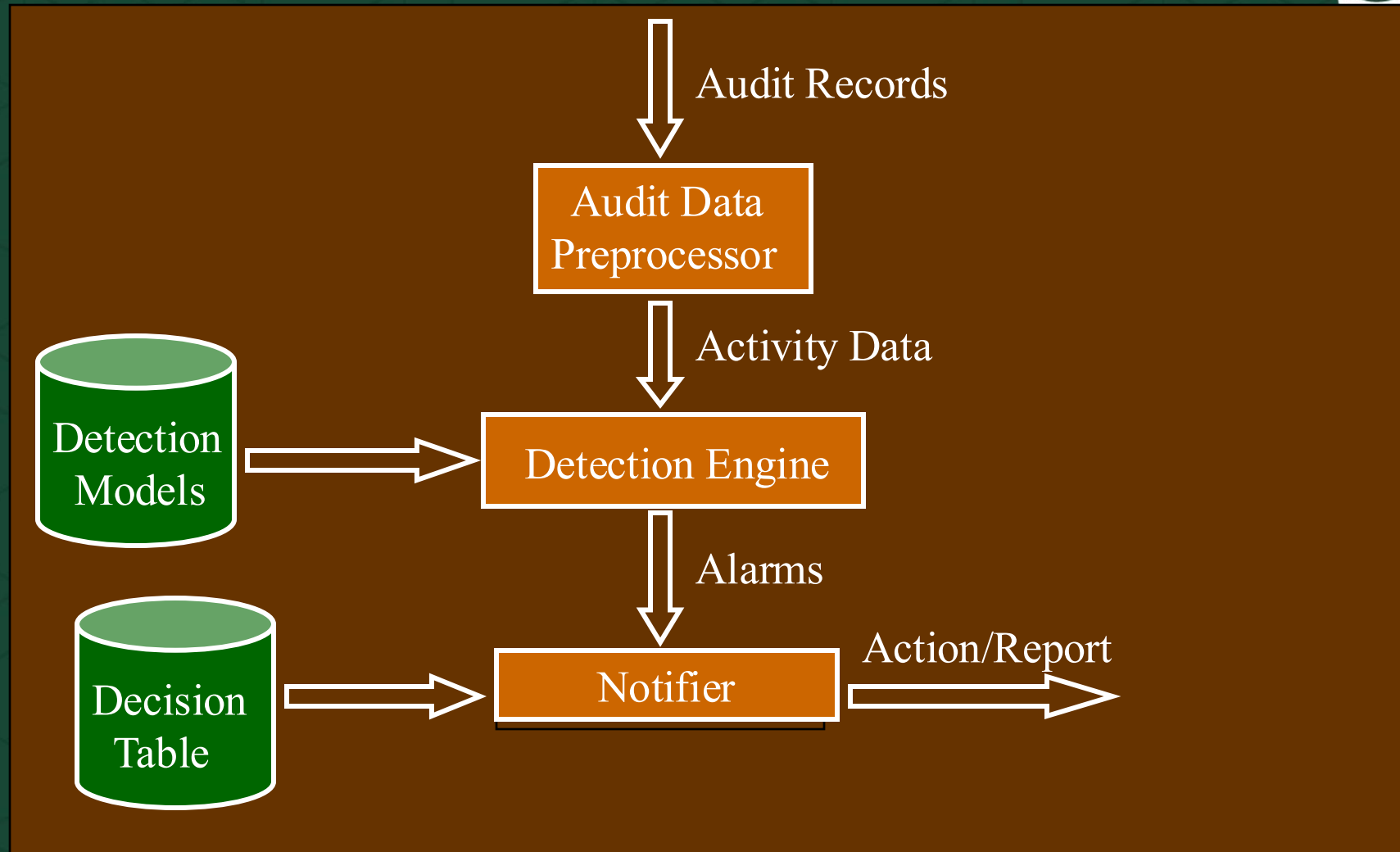
“Base-Rate Fallacy” Illustrated



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- IDS often suffers from base-rate fallacy
 - intrusions are rare events
 - non-intrusions are common
 - correctly detected intrusions are swamped by incorrectly detected non-intrusions!
- Example
 - an IDS reports 2800 alarms, of which 298 alarms are due to the actual intrusions
 - 298 out of 2800 alarms (10.6%) are correct. In reality, often less than 1% of alarms are real intrusions

Components of IDS





MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Signature-Based IDS

Basic IDS Techniques



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

1. Misuse detection

- use attack *signatures* (characteristics of real attacks, e.g., illegal sequences of system calls, invalid packets, etc.)
- can only detect already-known attacks
- false positive rate is low, but false negative rate is high

Example Signatures



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- A sequence of connection attempts to connect to a large number of ports
- A privileged program triggered by a shell
- A network packet that has lots of NOP instruction bytes (0x90) in it. This usually indicates a remote buffer overflow exploit
- Program input containing a very long string (parameter value)
- A large number of TCP SYN packets sent, with no ACKs coming back

Detection (Cont'd)



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

2. Anomaly detection

- uses a model of “normal” system behavior
- tries to detect deviations from this behavior, e.g., raises an alarm when a statistically rare event occurs
- can potentially detect new (not previously-encountered) attacks
- low false negative rate, high false positive rate
- Which is better?

Signature or Anomaly?

Password file modified

?

Four failed login attempts

?

Failed connection attempts on 50
sequentially-numbered ports

?

User who usually logs in around 10am from
dorm logs in at 4:30am from an IP address
in Lower Slobovia

?

UDP packet to port 1434
(Slammer Worm)

?



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Signature Generation



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Research challenge: fast, automatic extraction of signatures for **new attacks**
 - **honeypots** are useful for attracting attacks to generate signatures
- Attack signatures are usually very specific
 - automated engines now generate unlimited **variants** of a single attack
 - program obfuscation, self-decrypting code
- Possible response: find attack characteristics that are **difficult to conceal** / obfuscate



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Anomaly-Based IDS

Anomaly Detection

- Collect a profile of “normal” behavior
 - called *training phase*
 - works best for small, well-defined, *stable* systems
- IDS compares operational system to this profile, and flags *deviations*



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Examples of Metrics

- Count of the number of occurrences of an event per unit time
 - if count exceeded, raise an alarm
- Time elapsed between events
 - if time too small, raise an alarm
- Resource utilization
 - if utilization too high, raise an alarm
- Statistical measures
 - mean, standard deviation, etc.



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Examples (Cont'd)

- Short sequences of events
 - ex. suppose the normal sequences of system calls during execution of two programs has been measured
 - any serious deviation from such sequences will be flagged as possible signs of an attack



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Building Profiles

- Profiles are updated regularly, and older data must be "aged" out
- Risk: attacker trains IDS to accept his activity as normal
 - i.e., training data should be free of intrusions, or intrusions must be properly classified in the training data!



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Conventional View



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Anomaly-based IDS by itself generates too many false positives
- Combining anomaly-based and signature-based can better reduce false negatives and false positives.



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Host-Based vs. Network- Based IDS

Where Is the IDS Deployed?



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
ROLLA, MISSOURI

- Host-based intrusion detection monitor activity on a single host
- Network-based intrusion detection (NIDS) monitor traffic, examine packet headers and payloads

Host-Based IDS

- Use OS auditing and monitoring mechanisms to find applications taken over by an attacker. Ex.:
 - log all system events (e.g., file accesses)
 - monitor shell commands and system calls executed
- Advantage: better visibility into behavior of individual applications running on the host



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Host-Based (Cont'd)

- Limitations
 - need an IDS for every machine
 - if attacker takes over machine, can tamper with IDS binaries and modify audit logs
 - only local view of the attack



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Rootkit

- Rootkit is a set of “Trojan” system binaries
- Break into a host, download rootkit by FTP, unpack, compile and install
- Possibly turn off anti-virus / IDS
- Hides its own presence!
 - installs hacked binaries for common system monitoring commands, e.g., **netstat, ps, ls, du, login**
- “Sniff” user passwords



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Network-Based IDS

- Inspects network traffic
 - passive (unlike packet-filtering firewalls)
 - often handled by a router or firewall
- Monitors user activities
 - e.g., protocol violations, unusual connection patterns, attack strings in packet payloads
- Advantage: single NIDS can protect many hosts and look for widespread patterns of activity



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY

— ROLLA, MISSOURI —

Network-Based ... (cont'd)

- Limitations
 - may be easily defeated by encryption (data portions and some header information can be encrypted)
 - not all attacks arrive from the network
 - must monitor, record and process huge amount of traffic on high-speed links
- Attack: overload NIDS with huge data streams, then attempt the intrusion

Popular NIDS : Snort

- Open-source tool with a large (> 4000) ruleset for vulnerabilities

- Some Snort Rule Categories:

• Backdoors	Multimedia	POP	Telnet
• Chat	MySQL	RPC	TFTP
• DDoS	NETBIOS	Scan	Virus
• Finger	NNTP	Shellcode	Web...
• FTP	Oracle	SMTP	X11
• ICMP	P2P	SNMP	SQL
• IMAP			



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Snort Rule Syntax



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Each snort rule has two logical sections: rule header and rule options
 - rule header contains action, protocol, source (IP address/port), direction, destination (IP address/port)
 - rule option contains alert messages, info on which parts of packet to be inspected

Detecting Attack Strings



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Scanning for a signature in each packet is not enough
 - attacker can split attack string into several packets; will defeat stateless NIDS
- Recording just previous packet's text is not enough
 - attacker can send packets out of order
- Attacker can use TCP tricks so that certain packets are seen by NIDS but dropped by the receiving application

Summary



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

1. Firewalls are widely used, packet filters most common
2. IDS (both host-based and network-based) is widely used
3. Attacks are constantly evolving; the “arms race”
4. False alarm volume, and providing clear feedback to administrators, is a problem